Compte rendu d’audit ÉnergieAlp

# Simulation documentaire à échelle réduite
# Plan de remédiation priorisé

**Olivier HIMBLOT** · Formation AIS
Livrable formateur · Version 1.1 · 16 octobre 2026

## Compétence évaluée

Participer à la mesure et à l’analyse du niveau de sécurité de l’infrastructure.

## Critère fourni

« Simule, à échelle réduite, un audit ANSSI sur l’infrastructure d’ÉnergieAlp afin de qualifier les écarts résiduels et de proposer un plan de remédiation priorisé. »

**Preuve de travail :** compte rendu d’audit avec plan de remédiation.

## Synthèse pour le formateur

L’examen documentaire du scénario relève un VPN sans MFA, des accès de tiers sans revue documentée, des lacunes de gouvernance cloud et un inventaire incomplet. Les mesures proposées dans le mémo ne démontrent pas leur correction : ces points restent ouverts sur le plan documentaire. Le rapport relie ces constats aux actions AS-01 à AS-06 et à leurs critères de clôture.

**Portée :** simulation sur une entreprise fictive ; aucun accès à une infrastructure réelle ni test technique exécuté. La tenue d’un entretien collectif et la validation du formateur ne sont pas attestées. Ce document constitue une analyse documentaire rédigée, sans attester un audit officiel de l’ANSSI.

| Produit dans ce rapport | Reste à établir |
|---|---|
| Périmètre, sources, constats, qualification des limites, actions et suivi. | Entretiens réels, configurations, tests, coûts chiffrés, décisions et recontrôles. |

# 1. Périmètre, méthode et traçabilité

## Périmètre réduit

SCADA/supervision, compteurs communicants, CRM/facturation, plateforme analytics et VPN technicien. Tiers étudiés : GridSoft Solutions, CloudPeak Americas et RéseauTech Maintenance. L’examen porte sur les accès, les dépendances, les garanties et le pilotage documentaire ; il ne couvre pas chaque configuration ni chaque exigence du référentiel.

## Base de comparaison

ReCyF v2.5 du 17 mars 2026, conservé comme document de travail dans le parcours pédagogique. Les critères EE sont conditionnés par l’hypothèse de qualification EE, à confirmer. Les correspondances NIS2 du mémo ne valent pas conclusion juridique définitive. PASSI est une référence méthodologique, pas une qualification revendiquée de cet exercice.

| ID | Pièce examinée / origine | Portée |
|---|---|---|
| S-01 | Dossier entreprise ÉnergieAlp, annexe du module, §2 à §5. | Faits fournis du scénario ; aucune observation en production. |
| S-02 | Itération 2 : registre des actifs critiques. | Cotation et inventaire pédagogiques V0. |
| S-03 | Itération 2 : matrice ReCyF, analyse Cloud Act, politique et procédures tiers. | Propositions documentaires ; adoption non attestée. |
| S-04 | Itération 3 : matrice des risques fournisseurs, §4 à §6. | Scénarios, plan AS et indicateurs K ; réalisation non démontrée. |
| S-05 | Itération 3 : feuille simulation d’audit et clôture. | Méthode, trames et attentes de la séance. |

Sources locales consultées pour la rédaction du 16/10/2026. Leur date de consultation ne devient pas la date d’un entretien ni d’un contrôle technique. Les chemins et références figurent en page 7.

## Méthode et limites

Comparer faits du scénario, critères retenus et productions disponibles ; distinguer manque de preuve et défaillance établie ; rattacher chaque constat à un risque et une action. La priorité est qualitative et contextuelle. Aucun score de vulnérabilité, taux de conformité ou niveau résiduel chiffré n’est calculé sans données.

## Personnes interviewées

**Aucun entretien réalisé n’est attesté dans les éléments disponibles.** Les fonctions DSI, RSSI et responsable Production sont des rôles du scénario. Elles ne constituent pas une liste de personnes rencontrées. La date, les participants et leurs retours sont à consigner lors de la séance.

# 2. Questions d’audit et constats

Les questions ci-dessous ont été traitées par examen du dossier. Elles n’ont pas été posées à des personnes identifiées. Les réponses sont des synthèses documentaires attribuées aux sources S-01 à S-04.

| ID / question examinée | Résultat documentaire / preuve | Qualification |
|---|---|---|
| EC-01 — Le VPN distant dispose-t-il d’une authentification renforcée ? | S-01 §4 : identifiant et mot de passe sans MFA pour techniciens et RéseauTech. Aucune preuve de correction. | Écart du scénario ; 8.3-EE retenu sous hypothèse EE. Accès à la supervision : priorité P1. |
| EC-02 — Les accès des tiers sont-ils inventoriés et revus ? | S-01 §4 : accès GridSoft/RéseauTech à la demande, sans stratégie ni revue périodique documentée. | Lacune de maîtrise des accès ; critères de revue du parcours 10.A/10.C. Canal et droits exacts à établir. P1. |
| EC-03 — La décision cloud est-elle justifiée et encadrée ? | S-01 §4 : pas d’analyse de risque formalisée ni contrat pour CloudPeak. S-03 : analyse proposée. | Écart documentaire ; critères 3.B et gestion des risques du parcours. Aucun transfert US ni demande d’accès prouvé. P1. |
| EC-04 — Le périmètre critique est-il recensé complètement ? | S-01 §4 : registre existant incomplet. S-02 propose cinq services, sans rapprochement opérationnel. | Écart documentaire ; objectifs de connaissance du SI, critères 1.1 à 1.3 et 5.A.1 retenus. P2, à relever si actif critique omis. |
| EC-05 — La reprise est-elle démontrée ? | Aucun résultat de restauration ou réversibilité fourni ; S-04 prévoit AS-04. | Non vérifiable : ne prouve pas l’absence de sauvegarde ni un échec de reprise. Vérification P1 avant bascule. |

## Lecture des résultats

Quatre constats reposent sur les faits explicites du scénario ; un contrôle de reprise reste non vérifiable. Ce décompte décrit cet échantillon uniquement. Les rattachements détaillés et l’applicabilité des MAC sont conservés dans S-03/S-04 ; aucune conformité globale n’est déduite.

## Qualification des écarts résiduels

À la clôture de cet examen documentaire, EC-01 à EC-04 restent ouverts faute de preuve de correction. EC-05 demeure non vérifiable. Il s’agit du reliquat documentaire, pas d’un résiduel mesuré après déploiement : le niveau de risque après mesures reste non évalué.

# 3. Plan de remédiation priorisé

**J = date future d'approbation du plan.** Les échéances sont des cibles proposées, pas des engagements signés. Les identifiants AS existants sont conservés. P1 : traitement prioritaire ; P2 : consolidation planifiée, à reclasser selon les faits nouveaux.

| Action / priorité / horizon | Pilote et jalons proposés | Preuve nécessaire à la clôture |
|---|---|---|
| AS-01 / EC-02 — P1 Court terme (< 6 mois) Recenser et revoir les accès tiers. | DSI / Production, RSSI en coordination. Inventaire J+7 ; première revue J+15. | Liste réconciliée, propriétaires, droits approuvés, durées ; retraits et expirations testés. Canal GridSoft clarifié. |
| AS-02 / EC-01 — P1 Court terme (< 6 mois) Protéger les accès VPN par MFA. | DSI avec Production/RSSI. Étude MFA et secours J+7 ; déploiement après essais en fenêtre validée. | Facteur de connaissance et second facteur vérifiés ; essais de succès/refus, secours et continuité ; exceptions bornées. |
| AS-03 / EC-03 — P1 Court terme (< 6 mois) Qualifier et encadrer CloudPeak. | DSI/RSSI, juridique/achats proposés. Collecte et contractualisation lancées J+7 ; orientation J+30. | Analyse des flux/accès/juridictions, garanties signées et décision documentée. Résiduel réévalué sur pièces. |
| AS-04 / EC-05 — P1 Court terme (< 6 mois) Démontrer reprise et réversibilité. | DSI et métiers. Objectifs et plan de test J+30 ; recette avant sortie ou bascule. | DMIA/PRD validés ; export, restauration et retour arrière mesurés ; validation métier et limites. |
| AS-05 / EC-04 — P2 Court terme (< 6 mois) Compléter actifs et dépendances. | Production / DSI et métiers. Dossiers techniques et données J+30. | Rapprochement du registre, versions/supports, maintenance, accès physiques et nécessité des données analytics. |
| AS-06 / EC-02 à 04 — P2 Court terme (< 6 mois) Organiser le contrôle des tiers. | RSSI, responsables internes et direction. Plan de vérification et revue J+30. | Fiches, contacts, clauses, revue des risques ; contrôles exécutés et résultats conservés pour les engagements retenus. |

## Pourquoi cet ordre ?

Le VPN et les droits tiers peuvent donner accès à la supervision : impact potentiel sur un service électrique continu. Les garanties cloud et la reprise soutiennent la protection et la continuité du CRM/analytics. L'inventaire et la gouvernance renforcent ces traitements ; un actif critique oublié ou une exposition nouvelle impose de réviser leur priorité.

**Contraintes :** fenêtres validées, nuit/hors pics pour supervision et SI clientèle, sauf urgence avérée. Toute modification prévoit essais, approbation, secours et retour arrière. Pas de retrait massif ni de migration précipitée sans analyse des dépendances.

# 4. Coût, risque restant et surveillance

## Évaluation économique à obtenir avant engagement

| Action | Postes à chiffrer / source attendue |
|---|---|
| AS-01 | Jours-personnes d’inventaire, revue et retrait ; estimation DSI/Production. |
| AS-02 | Licences/facteurs MFA, intégration, recette, secours et formation ; devis et charge DSI. |
| AS-03 | Analyse juridique, négociation et éventuel pilote/migration ; devis achats et prestataires. |
| AS-04 | Environnement de recette, stockage/export, temps de restauration et validation métier. |
| AS-05 / AS-06 | Recensement, qualification technique, contrôles fournisseurs et audits ; charge et devis. |

Montants en euros et charges non disponibles : **à chiffrer**. Proposition : recueillir une première estimation à J+7 pour les P1 et à J+30 pour les P2, avec source, date et incertitude. Direction et responsables métiers arbitrent ressources et dates ; tout retard reste visible.

## Mesures transitoires et risque restant

À instruire avec DSI/Production : restreindre les accès au besoin justifié, borner leur durée, surveiller les connexions et accélérer la revue des droits. Ces mesures sont proposées ; leur présence ou efficacité n’est pas attestée. Elles ne valent pas correction automatique de l’absence de MFA.

Pour chaque risque : noter mesures vérifiées, pièces, niveau restant motivé ou « non évalué », décision, autorité, date et expiration. Le scénario réserve au RSSI la validation d’une dérogation de sécurité ; cela ne permet pas de déroger à une obligation légale applicable.

## Indicateurs proposés : valeurs initiales non mesurées

| Indicateur / source | Cible et revue |
|---|---|
| K-02 : droits tiers revus / droits recensés ; exports et compte rendu. | 100 % proposé ; DSI, suivi mensuel et revue trimestrielle. |
| K-03 : accès concernés protégés et testés avec MFA / accès concernés recensés. | 100 % proposé ; DSI, mensuel et après changement ; exceptions distinctes. |
| K-04 : nombre de P1 après échéance approuvée ; registre AS. | 0 ; RSSI, hebdomadaire ; escalade et décision sur chaque retard. |
| K-06 : scénarios prioritaires testés et acceptés / scénarios prioritaires planifiés. | 100 % du programme proposé ; DSI/métiers, à chaque test. |

Dénominateur inconnu : non calculable ; dénominateur nul : sans objet, à justifier. Afficher périmètre, date, source et effectifs. Propositions de surveillance : revue mensuelle du plan, audit interne annuel et revue de direction annuelle ; réexamen après incident ou changement significatif. Ces rythmes locaux restent à approuver.

# 5. Trajectoire à court, moyen et long terme

**Point de départ : J, approbation future du plan.** Les horizons portent sur le délai depuis J. Court terme : moins de 6 mois ; moyen terme : de 6 mois à 1 an inclus ; long terme : plus d'un an. Ce sont des cibles proposées à faire approuver.

| Horizon / cible | Actions et responsables proposés | Résultat attendu / preuve |
|---|---|---|
| COURT TERME Moins de 6 mois Cible : J+1 à J+5 mois | DSI / Production / RSSI : exécuter AS-01 à AS-06. Inventorier et revoir les droits, déployer et tester le MFA, analyser et encadrer CloudPeak, tester la reprise, compléter les actifs et lancer les contrôles tiers. Conserver les jalons J+7, J+15 et J+30. | Traiter les écarts prioritaires ; clôturer seulement sur preuves et recontrôle. Valider la date de déploiement MFA après l'étude J+7, avec cible avant J+6 mois ; assurer les mesures transitoires jusqu'à la recette. |
| MOYEN TERME De 6 mois à 1 an inclus Cible : J+6 à J+12 mois | RSSI / DSI / métiers : consolider AS-01 à AS-06 par des revues répétées, un audit interne, un nouvel exercice de reprise et une revue de direction. Conduire un pilote puis une migration cloud uniquement si l'analyse AS-03 la justifie. | Démontrer la tenue des mesures dans le temps : rapports, indicateurs comparés, tests et décisions. Si migration retenue : recette, continuité, réversibilité et coûts approuvés avant bascule. |
| LONG TERME Plus d'un an Cible proposée : J+18 à J+24 mois | Direction / RSSI / DSI / Production : pérenniser le programme de contrôle et les budgets ; réexaminer risques, fournisseurs et architecture. Programmer les évolutions structurelles ou renouvellements justifiés par les études. | Bilan annuel comparatif, trajectoire d'investissement validée, contrôles récurrents et tests actualisés. Chaque évolution conserve son étude d'impact, ses critères de recette et son retour arrière. |

## Séparer correction initiale et amélioration continue

Les six actions initiales visent le court terme. Les horizons moyen et long terme prolongent leur efficacité et organisent les transformations éventuelles. Ils ne reportent pas automatiquement la correction du VPN sans MFA, les revues d'accès ni l'encadrement contractuel. Aucun besoin de migration ou de refonte n'est considéré comme établi sans analyse.

## Revoir les échéances et arbitrer les retards

À chaque revue mensuelle, comparer dates approuvées, résultats et preuves. Un retard de P1 déclenche un arbitrage avec mesure transitoire, pilote, nouvelle date justifiée et suivi du risque. Tout constat critique nouveau peut imposer une action immédiate, quel que soit l'horizon initial.

# 6. Conclusion et remise au formateur

## Conclusion de l’examen documentaire

Le dossier permet d’identifier et de prioriser des faiblesses cohérentes avec les enjeux d’ÉnergieAlp. Il montre une démarche de mesure qualitative : faits sourcés, critères conditionnés par leur applicabilité, distinction entre écart et absence de preuve, actions avec jalons et critères de contrôle. Il ne permet pas de conclure à une conformité opérationnelle ni à une réduction effective du risque.

| Critère d’évaluation | Élément présenté |
|---|---|
| Simulation à échelle réduite | Périmètre et méthode page 2 ; questions d’audit et réponses documentaires page 3. |
| Qualification des écarts résiduels | Constats ouverts, limites et distinction reliquat documentaire / risque après mesures page 3. |
| Plan priorisé | AS-01 à AS-06 page 4 ; horizons court (< 6 mois), moyen (6 à 12 mois) et long (> 1 an) page 6. |
| Pilotage | Coûts à établir, décisions de risque, indicateurs et revues page 5. |

## Pièces et références pour retrouver le raisonnement

S-01 — docs/droit-conformite/annexes/dossier-entreprise-energiealp.md

S-02 — docs/droit-conformite/it-2/registre-actifs-critiques.md

S-03 — docs/droit-conformite/it-2/debrief-matrice-cloud-act-politique-securite.md

S-04 — docs/droit-conformite/it-3/matrice-risques-sous-traitants-preparation-audit.md

S-05 — docs/droit-conformite/it-3/simulation-audit-anssi-remediation-cloture.md

Références méthodologiques et pédagogiques reprises du mémo :
ANSSI — PASSI v2.2 ; ReCyF v2.5 du 17/03/2026, document de travail. Leur mention ne constitue ni un contrôle juridique actualisé ni une reconnaissance de conformité.

**État de remise :** compte rendu documentaire et plan proposés disponibles. Entretien collectif, mise en œuvre, preuves techniques, coûts et validation du formateur à compléter.